

PRD: Non-Human Identity Risk Quantification

Securing the Unmanaged Frontier Within Qualys ETM Identity

Team	Identity Security Platform (ETM Identity)
Contributors	Kushal Zambare (Product Manager)
Status	In Development
Target Launch	Q3 2026 (v0 — Discovery & Inventory)
Resources	Based on public Qualys ETM Identity materials, Oct 2025 ROCon

Portfolio Disclaimer: This PRD is written by Kushal Zambare based solely on public Qualys ETM Identity materials. It is not affiliated with or endorsed by Qualys, Inc. All sizing numbers are illustrative assumptions.

Problem Definition

While enterprises run **IAM, IGA, PAM, and ITDR tools**, identity-driven breaches persist and are among the most expensive to resolve. The root cause: **Non-Human Identities (NHIs)** — service accounts, machine identities, API keys, and agentic-AI agents, are completely unmanaged. They outnumber humans **50:1**, rarely have MFA, rotate slowly, and have no clear owner. Security teams cannot answer three questions that determine response: Which NHIs are dangerous? Who owns them? What breaks if we shut them off?

Core insight: The problem is not lack of tools Reviewing your **Associate Product Manager resume** it is lack of a unified risk language and a closed remediation loop for NHIs. Existing tools govern who should have access; none quantify which identities are exploitable and map the attack path to crown-jewel assets.

Goals

Reduce enterprise identity-driven breach risk by quantifying NHI exposure, attributing ownership, and surfacing actionable attack paths all within the existing Qualys TruRisk™ language and ROC workflow.

To influence # quality (exploitability, blast-radius, recency) NHI risk remediations, the goal is to increase:

- **% of NHIs with attributed owners** (target: ≥80% within 6 months of v1 GA)
- **NHI discovery coverage** (target: ≥95% enumeration within one scan cycle)
- **% reduction in open toxic attack paths** to Tier-0 / crown-jewel assets (QoQ)
- **Mean Time To Remediate (MTTR)** a flagged NHI (from weeks to days)

Business – Product Outcome Mapping

Items in green are Business Outcomes. Items in red are Product Outcomes. Follow the red line.

Business Outcome	Platform Metric	Product Outcome (Focus)	Why This Outcome
↑ TruRisk Score Improvement (Customer)	↓ Aggregate NHI Identity TruRisk Score QoQ	↓ # toxic attack paths to Tier-0	Direct proxy for exploitable identity exposure
↑ ARR / Renewal Rate	↑ ROC Analyst Weekly Active Users on NHI worklist	↑ % NHIs with attributed owner	Drives adoption — unattributed = unactioned
↑ Platform Stickiness	↑ % of rec's → ITSM tickets	↑ NHI discovery coverage (≥95%)	Coverage gaps = blind spots = breach risk

↓ Breach Cost for Customers	↓ MTTR on flagged NHI (weeks → days)	↓ MTTR on flagged NHI	Measurable risk reduction in customer environment
↑ Product Differentiation	Unique:Unified Vuln+Asset+Identity Score	✓ ONLY — no IGA/ITDR tool produces this	0 competitors produce a unified TruRisk score across all three surfaces

Success Metrics

Metric	Type	Priority	Why It Matters
↓ Aggregate NHI Identity TruRisk Score (QoQ)	North Star	Focus	Proves exploitable identity exposure is actually reducing — not just more tickets being closed
↓ # open toxic attack paths to Tier-0 assets	Functional	L1	Direct measure of blast-radius exposure — the thing that causes breaches
↑ NHI discovery coverage (% of est. population)	Functional	L1	Coverage below 95% means blind spots — unmanaged NHIs that could be exploited
↑ % NHIs with attributed owner	Functional	L1	Unattributed = unactioned. Owner attribution is the prerequisite for any remediation
↓ MTTR on a flagged NHI (target: days, not weeks)	Functional	L1	Speed of remediation is the clearest signal the closed loop is working
↑ % recommendations converted to ITSM tickets	Functional	L1	Measures workflow adoption — are analysts using the ROC-to-ITSM loop or ignoring it?
↑ Pass rate on TruConfirm re-validation	Functional	L2	Confirms risk actually dropped — not just ticket closed. Guards against false closure
↑ Weekly active ROC analysts on NHI worklist	Functional	L2	Platform stickiness and adoption signal
↓ % high-risk NHIs still 'unattributed'	Functional	L2	Inverse of ownership metric — tracks the gap shrinking over time
Review Abandonment Rate (ITSM tickets not actioned)	Failure	Failure	If tickets are generated but not actioned, the loop is broken — escalate to PM
Scan performance impact on identity sources	Non-Functional	L3	Discovery must not degrade IdP performance — a deal-breaker with enterprise customers
ASR / API response time (voice-to-text, if applicable)	Non-Functional	L3	Latency above threshold degrades analyst experience
Crash rate across OS/device (agent-based collection)	Non-Functional	L3	Agent stability is critical for continuous discovery

Only the functional metrics above are directly controlled by the Identity Platform team. Non-functional metrics are monitored by Platform Engineering. Failure metrics trigger a rollback review.

Non-Goals

The following are explicitly excluded from this PRD's scope:

- **Identity Governance & Administration (IGA) / Provisioning:** We consume IGA data as a signal source (SailPoint, Saviynt). We do not provision, deprovision, or manage access lifecycle. That is a separate product category.
- **PAM / Secrets Vault:** We read risk signals from CyberArk, Delinea, HashiCorp Vault. We do not store, rotate, or distribute secrets in v1–v2.
- **Human Identity Risk Management:** ETM Identity already covers human identity risk. This PRD scope is NHI-specific: service accounts, machine identities, API keys, agentic-AI agents.
- **Automated Credential Rotation (v1–v2):** Recommend-and-ticket only in v1–v2. In-platform orchestrated rotation is explicitly v3 scope.
- **Zomato, Blinkit, other verticals:** Out of scope for obvious reasons. This is a Qualys identity security PRD.

Excluded metric: Avg Order Value, # positive/negative reviews, photo review rate — there is no Zomato here. Equivalent exclusions: breach cost attribution, NPS scores, IGA certification completion rates — all beyond the identity platform team's control.

User Segmentation

From the product outcome mapping, it is evident that ROC Analysts and IAM Administrators who respond to identity risk daily are highly active and motivated. Hence easier to influence first.

Persona	Freq of Use	Review Importance	Segment	Why Target First
ROC / Identity Security Analyst	Daily (worklist)	High — acts on every alert	Loyal Operator (daily remediation)	Highest influence on north-star metric. Fixes the risk directly.
IAM / IdP Administrator	Weekly (executes fixes)	High — executes remediation	Casual Executor (executes on ticket)	Second in chain — must trust the recommendation to act without fear
CISO / Security Leader	Monthly (dashboard)	Medium — tracks trend	Executive Consumer (views aggregate risk)	Sponsors renewal. Needs one credible number for board reporting.
App / Service Owner	Per-incident	Low — only when their service is flagged	Reluctant Actor (acts under pressure)	Hardest to convert — needs blast-radius + rollback context to act without paralysis
Compliance Audit Officer	Quarterly (audit)	Medium — evidence trail	Evidence Seeker (audit mode)	Valuable for retention — needs exportable, time-stamped trail

Size & Impact Analysis

Target Segment Identification

- Enterprises with ≥1,000 employees running AD, Entra ID, or Okta as primary IdP
- Currently using Qualys VMDR or ETM (existing install base — no greenfield sales required)
- Have ≥1 ROC Analyst or Identity/IAM team actively monitoring identity posture

Assumptions

Due to the absence of internal Qualys data, the following assumptions are taken after careful consideration of public breach data and industry research:

Assumption	Value	Source / Rationale
Qualys enterprise customer base	~3,000 enterprise accounts	Qualys FY24 public earnings — approximately 10,000 customers, est. ~30% enterprise tier
Avg NHIs per enterprise (est.)	~50,000 NHIs	Industry benchmark: NHIs outnumber humans 50:1; avg 1,000 employees → ~50,000 NHIs
% NHIs currently unmanaged/unattributed	~80% (~40,000 per customer)	No major enterprise has solved this — consistent with Silverfort, CyberArk public research
% toxic paths remediable with ETM Identity	~15% of unmanaged NHIs	Conservative: ~6,000 actionable NHIs per customer
Avg breach cost attributable to stolen credentials	\$4.88M per incident	IBM Cost of a Data Breach Report 2024
Breach probability reduction per 100 toxic paths closed	~0.05% reduction	Illustrative — based on identity-related breach frequency in Verizon DBIR 2024
ETM Identity ACV uplift potential (per customer)	\$25,000–\$50,000	Illustrative — NHI scope as add-on module or tier upgrade
Target penetration in Year 1	10% of install base (300 customers)	Conservative adoption given new capability — design-partner model

Impact Calculation

Revenue Impact = Target Customers × ACV Uplift = 300 × \$37,500 avg = **\$11.25M incremental ARR in Year 1**

Risk Reduction Impact = 300 customers × 6,000 actionable NHIs × 0.05% breach prob reduction × \$4.88M avg breach cost = **~\$44M in avoided breach cost across install base**

Note: All numbers are illustrative assumptions based on public data. Not internal Qualys figures.

Problem Validation

The initial hypothesis behind low NHI management was assumed as:

- 1. **Lack of Visibility:** Security teams have no single view of all NHIs across AD, cloud IdPs, and vaults.
- 2. **Lack of Ownership:** No mechanism to attribute a human/team responsible for each NHI the 'orphaned account' problem.
- 3. **Lack of Prioritization:** A flat export of 40,000 NHIs is operationally useless. Teams need the handful that create real attack paths.
- 4. **Lack of a Closed Loop:** Even when a risky NHI is flagged, there is no proof the fix worked no re-validation mechanism.

Validation Approach

Hypotheses validated through: (1) public breach investigation reports (CISA, FBI IC3), (2) industry research (Verizon DBIR 2024, IBM Cost of Breach 2024, CyberArk Global Threat Landscape Report), (3) competitor gap analysis, (4) Qualys public positioning materials (ROCon Oct 2025).

Research Outcomes

Finding	Valid?	Evidence
80%+ of enterprise breaches involve compromised credentials (human or NHI)	✓	Verizon DBIR 2024 — credentials remain #1 attack vector for 8 consecutive years
NHIs outnumber human identities by 45–50x in average enterprise	✓	CyberArk 2024 Identity Security Threat Landscape Report
<20% of enterprises have full NHI inventory or ownership mapping	✓	Silverfort 2024 NHI Security Report — 83% of orgs have no NHI discovery process
Lack of Closed Loop — teams patch but cannot prove risk went down	✓	Common pattern in SOC tooling; validated in Qualys ETM positioning at ROCon 2025
No IGA/PAM/ITDR tool produces a unified risk score across vuln+asset+identity	✓	Competitor analysis: SailPoint, Saviynt, CrowdStrike, Silverfort — none produce this
Lack of Recall — teams forget which NHIs they identified previously	Not confirmed	Teams use spreadsheets; recall is poor but not the primary bottleneck

Competitor Research

Competitors in IGA, PAM, ITDR, and niche NHI verticals were analysed. Key finding: no competitor produces a unified Vuln + Asset + Identity TruRisk score, and very few have closed-loop ROC remediation workflows.

Capability	SailPoint	Saviynt	CrowdStrike	Silverfort	Qualys ETM Identity
NHI Discovery	—	—	—	✓	✓
Unified Vuln+Asset+Identity Score	—	—	—	—	✓ ONLY

Confidence-Based Ownership Attribution	—	—	—	—	✓ ONLY
Attack Path Graphing to Tier-0	—	—	Partial	Partial	✓
Closed-Loop ROC → ITSM → Revalidate	—	—	—	—	✓ ONLY
IGA/PAM Ingestion replace) Signal (not	Owns IGA	Owns IGA	—	—	✓ (consumes all)

Top 5 takeaways from research:

1. Security teams are intrinsically motivated to manage NHI risk but are paralysed by the absence of a prioritised, ownable worklist.
2. Analysts want to know which NHIs to fix first a flat export of 40,000 records is the exact problem, not the solution.
3. App/Service Owners have blast-radius paralysis they won't rotate a service account without knowing what breaks.
4. No competitor provides unified TruRisk scoring across identity + vulnerability + asset this is Qualys's defensible position.
5. Agentic AI is creating NHIs at machine speed the window for first-mover differentiation is open right now.

Understanding the Target Audience

Primary Persona — ROC / Identity Security Analyst

Anjali, 29	UNMET GOALS	PAIN POINTS
Sr. Identity Security Analyst FinTech, Mumbai "I get a list of 40,000 service accounts every Monday. I have no idea which ones will get us breached."	- Know which of her 40,000 NHIs could get the company breached today - Have a prioritised worklist she can action in her shift not a spreadsheet - Show her CISO a number that proves risk went down this quarter - Rotate a service account without fearing a 2am production incident	- Cannot find who owns 80% of her service accounts, orphaned for years - No tool shows her the attack path: 'this account → CI/CD → domain controller' - Existing IGA/ITDR tools show her everything is a problem, no prioritisation - When she fixes something, she has no proof it's gone

User Journey Map

Stage	Discovery	Prioritize	Remediate	Verify
Action	"Run NHI scan, export 40,000 rows, open spreadsheet"	"Try to guess which accounts are dangerous based on name patterns"	"Email App Owner — wait 2 weeks for a response"	"No idea if the account is actually disabled. Close the ticket anyway."
Thoughts	"Where are the accounts that can actually cause a breach?"	"Why can't I see which account reaches our payment database?"	"They're scared to rotate it — what if it breaks the pipeline?"	"Too much effort for no proof. Why does Qualys not tell me this worked?"
Emotion	Overwhelmed	Confused	Frustrated	Resigned

Unmet Needs / Pain Points

Pain Point	Alignment to Goal	Severity	Frequency	Ranking
No unified NHI inventory — accounts in AD, Entra, Okta, vaults, code	High 100% of NHIs affected	Critical you can't manage what you can't see	Every scan cycle	High (MVP P0)
No ownership attribution — 80% of NHIs are orphaned	High remediation is impossible without an owner	Critical every unattributed NHI is unactioned	Every remediation attempt	High (MVP P0)
No prioritisation — 40,000-row flat export is	High analysts	Critical — without priority, everything is	Every worklist session	High (MVP P0)

unusable	give up	equal urgency (= nothing is)		
No closed loop — no proof that remediation worked	High — CISO cannot report risk reduction	High — erodes trust in the tool over time	Every quarterly review	High-Med
Blast-radius paralysis — App Owners won't act without knowing dependencies	Medium — slows MTTR	High — a rotated account that breaks prod is worse than a risky one	Every remediation execution	High-Med

Given that **No Inventory**, **No Ownership**, and **No Prioritisation** are the three biggest blockers — all of which feed into each other — these form the MVP. Blast-radius paralysis is addressed with supporting context in the ITSM ticket.

Descoped

- **Automated credential rotation (v1–v2):** In-platform rotation is technically feasible but carries significant blast-radius risk. Without a proven re-validation mechanism (TruConfirm), automated rotation could break production. Descoped to v3 — after the closed loop is proven reliable.
- **GPT-based automatic review generation:** Using LLM to auto-write risk summaries is intriguing but produces hallucinated context in low-data environments (new NHIs). Risks misrepresenting severity to CISO. Descoped — may revisit in v3 with sufficient fine-tuning data.
- **Push notification remediation alerts to mobile:** Technical feasibility risk — deep-link into ITSM from mobile notification is inconsistent across enterprise MDM environments. Risks fragmented remediation workflow. Descoped for v1.
- **Monetary rewards for review/remediation:** Not applicable in B2B enterprise context. Equivalent: gamified leaderboard for 'most NHIs closed' was evaluated and rejected — trivialises a compliance function and may encourage gaming metrics.
- **IGA/PAM replacement:** ETM Identity is a risk overlay — not a foundation. Competing with SailPoint/CyberArk at their core function would require 5–10x the scope and would destroy the key differentiator (ingesting their data as a signal).

Solution Prioritization

Several product ideas were ideated to address the core bottlenecks of: no inventory, no ownership, no prioritisation, and no closed loop. Here are the top 3 solution approaches:

	Unified NHI Discovery + TruRisk Score	Confidence-Based Ownership Attribution	Attack-Path Graph + Closed Loop
How it works	Connectors to AD, Entra, Okta, IGA/PAM, cloud IdPs enumerate all NHIs into a single deduplicated inventory. Each NHI receives an Identity TruRisk score: Exposure × Exploitability × Blast Radius on the same 1-2000 scale as vulns and assets.	Infers a probable owner for each NHI using 4 signals: creating account, ServiceNow ticket history, host naming conventions, recent interactive users. Shows confidence %. One-click confirm/reassign. Human validation trains the model.	Graphs lateral-movement paths from a compromised NHI to Tier-0 assets. Ranks toxic paths by hop count. Identifies chokepoints (one fix collapses N paths). Remediation flows ROC → ITSM ticket → App Owner → TruConfirm re-validation.
Benefits	Turns 40,000-row flat exports into a ranked worklist. Same risk language as vulns — CISO compares apples to apples.	Removes remediation paralysis. App Owner gets a specific ticket with blast-radius note and rollback guidance.	Proves risk actually went down. CISO has a number for the board. Closes the remediation loop for the first time.
Risks	Connector coverage gaps = blind spots. Must surface coverage % so teams know what they can't see.	Wrong owner attribution = wrong ticket = lost trust. Confidence scoring + human-in-the-loop is the mitigation.	False-positive attack paths = noise = ignored. TruConfirm-style validation before a path is shown as exploitable.

RICE Prioritization

Solution	Reach (R)	Impact (I)	Confidence (C)	Effort (E)	Score = R×I×C/E
NHI Discovery + TruRisk Scoring	5	5	5	4	31.25 ★
Confidence-Based Ownership Attribution	5	5	4	4	25
Attack-Path Graph + Closed Loop	4	5	4	5	16
Blast-Radius + Rollback Guidance on Ticket	5	4	5	2	50 (low effort, high trust-builder)

User Stories

Below is the breakdown of key features with tasks/subtasks and acceptance criteria:

NHI Unified Inventory	"As an Identity Security Analyst, I want a single deduplicated inventory of all NHIs across on-prem and cloud, so that I have no blind spots."
Acceptance Criteria	1. NHIs from AD, Entra ID, Okta, and connected IGA/PAM sources are enumerated within one scan cycle. 2. The same NHI appearing in multiple source systems (e.g., svc-deploy in AD AND Entra) is merged into one record — not duplicated. 3. Each record shows: type, lifecycle state, entitlements, last-used timestamp, change history, source systems merged. 4. Inventory is filterable by type (service / machine / workload / agentic-AI), risk level, and ownership status. 5. Discovery coverage % is surfaced prominently — analysts can see what they can't see. 6. Target: ≥95% NHI enumeration coverage within one scan cycle on design-partner tenants.
Ownership Attribution	"As an IAM Administrator, I want a probable owner attributed to each NHI with a confidence score, so that I can route remediation without guessing."
Acceptance Criteria	1. Every NHI shows an inferred owner (or 'Unattributed') with a confidence percentage (e.g., 85% — DevOps Team B). 2. Four signals are used: creating account data, ServiceNow/Jira ticket history, host naming conventions, recent interactive users. 3. I can confirm or reassign the owner in one click — the change persists and improves the model for future NHIs. 4. 'Unattributed + high-risk' is available as a saved, sortable worklist view. 5. Bulk owner-assignment is supported for ≥100 NHIs in one action. 6. Target: ≥80% owner attribution accuracy after 90 days of human-confirmation feedback.
Identity TruRisk Scoring	"As a ROC Analyst, I want each NHI scored with an Identity TruRisk value reflecting real exploitability and blast radius, so that I work the 20 that matter — not the 20,000 that don't."
Acceptance Criteria	1. Each NHI displays an Identity TruRisk score on the 1–2000 scale with a contributing-factors breakdown (Exposure / Exploitability / Blast Radius split). 2. Score incorporates live threat-intelligence context (active targeting of this identity class), not just static configuration. 3. Re-scoring occurs within one cycle of any state change: privilege escalation, credential age change, new threat intel. 4. Analysts can sort and threshold by score to build a personalised worklist. 5. Score is in the same 1–2000 language as vulnerability and asset TruRisk — no new language to learn.

Attack-Path Prioritization	"As a ROC Analyst, I want to see the lateral-movement attack paths a compromised NHI enables toward critical assets, so that I fix the chokepoints that collapse many paths at once."
Acceptance Criteria	1. Selecting an NHI renders its outbound attack paths as a directed graph to Tier-0 / crown-jewel assets. 2. Paths are ranked by number of hops to the nearest critical asset — shortest route first. 3. Chokepoint NHIs (where fixing one NHI collapses N paths) are surfaced and ranked by path-collapse count. 4. The graph label makes clear: 'Remediation triggered via ITSM ticket — not automated blocking in v1.' 5. Remediating a chokepoint visibly reduces the open toxic-path count in real time (post TruConfirm re-validation).
ROC → ITSM Closed Loop	"As a CISO, I want remediation to flow through ServiceNow/Jira with verified before/after risk, so that I can show the board that identity exposure actually went down."
Acceptance Criteria	1. Clicking 'Remediate' on a flagged NHI or chokepoint auto-generates an ITSM ticket with: owner name, blast-radius note (what depends on this NHI), rollback guidance, and current TruRisk score. 2. Ticket is assigned to the attributed owner automatically. 3. On ticket closure, TruConfirm re-validation re-checks the attack path — confirming it is actually gone, not just the ticket closed. 4. Identity TruRisk score updates on confirmed closure. 5. A QoQ trend view shows aggregate NHI TruRisk score over time, sliceable by business unit or asset classification. 6. An exportable, time-stamped audit trail records every state change for compliance purposes.
Blast-Radius + Rollback Guidance	"As an App/Service Owner, I want to know exactly what depends on this service account before I rotate it, so that I can act without fearing a 2am production incident."
Acceptance Criteria	1. Every ITSM ticket generated by ETM Identity includes a Blast-Radius Note: list of services/apps that call this NHI. 2. Rollback guidance is included: step-by-step instructions to reverse the rotation if it causes an incident. 3. A 'Staged Rotation' option (rotate in dev → stage → prod) is offered where dependency analysis supports it. 4. The App Owner can confirm or reject the blast-radius list — their input improves the dependency model.

Risk & Mitigation

Risk	Mitigation
Value Risk: Wrong owner attribution = wrong ticket = analyst loses trust in the tool	Confidence scoring shown on every attribution. Human confirm/reassign loop trains the model. Analysts can override. Attribution quality KPI tracked (target ≥80% after 90 days).
Usability Risk: Attack-path graph is noisy — too many paths shown, analysts give up	TruConfirm-style validation gate: a path is only shown as 'exploitable' after automated re-validation. Chokepoint view collapses complexity. Analyst can filter by hop count / risk score.
Feasibility Risk: Connector gaps leave NHIs undiscovered — analysts believe coverage is complete when it isn't	Coverage % surfaced prominently in the UI. 'Known unknown' feature: ETM Identity flags connector types that are configured but returning partial data. Never imply 100% coverage.
Feasibility Risk: Offline/device-bound ASR for voice review (if applicable) requires processing power — limits reach to newer devices	Online ASR (Google Cloud Speech, AWS Transcribe) as automatic fallback if device CPU/memory cap is hit. Feature gracefully degrades to text input — never blocks submission.
Scalability Risk: NLU-based content moderation at scale — manually reviewing 40M+ NHI state changes is impossible	NLU pipeline handles content filtering at scale. Human-in-the-loop for edge cases only. NLU accuracy tracked as a non-functional metric.
Trust Risk: CISO sees TruRisk score drop after remediation — then a breach occurs anyway. Questions validity of score.	TruRisk score is a probability-weighted risk indicator, not a guarantee. Clear comms in UI: 'This score reflects known exploitability. Unknown vectors are not captured.' Transparency over false precision.
API Down: ITSM integration failure breaks the remediation loop	Graceful degradation: remediation recommendations remain visible with a 'copy to clipboard' option for manual ITSM entry. Alert to platform team if ITSM API down >5 min.
Adoption Risk: App Owners ignore ITSM tickets — the blast-radius note is not convincing enough	A/B test: ticket with vs without staged-rotation option. Track ticket acceptance rate by persona. If <30% acceptance in 60 days, escalate to PM for blast-radius note redesign.

Data & Logic Changes

Algorithm / Logic Changes

- New Identity TruRisk Calculation: $\text{Per-NHI score} = \text{Exposure_weight} \times \text{Exploitability_score} \times \text{Blast_Radius_multiplier}$. Score normalised to 1–2000 scale. Re-calculated within one scan cycle of any state change. Weighted recency: $0.6 \times \text{current_state_score} + 0.4 \times \text{historical_avg_score}$.
- Ownership Attribution Model: Confidence score = weighted sum of 4 signal scores (creating account: 0.30, ticket history: 0.30, naming convention: 0.20, recent interactive users: 0.20). Human confirmation events update signal weights over time via Bayesian update.
- Attack-Path Rank: Paths ranked by $\text{weighted_hop_count} \times \text{asset_criticality_multiplier}$. Chokepoint score = # paths that pass through this NHI $\times \text{path_rank_avg}$.
- TruConfirm Re-validation Logic: On ticket closure event, re-scan the specific NHI's entitlements and attack-path graph. If path still exists after claimed remediation → reopen ticket automatically with 'Re-validation Failed' status.

Schema Changes & New Data Types

Field Name	Data Type	Nullable	Source	Description
<code>nhi_id</code>	UUID	NOT NULL	Discovery Agent	Primary key. Unique NHI identifier. Stable across scan cycles — not regenerated on rescan.
<code>nhi_display_name</code>	VARCHAR(255)	NOT NULL	IdP Source	Human-readable NHI name from originating IdP. Preserved as-is. Example: svc-deploy, pipeline-agent-prod.
<code>nhi_type</code>	ENUM	NOT NULL	Discovery Agent	NHI class: service_account machine_identity api_key workload_identity agentic_ai other.
<code>nhi_lifecycle_state</code>	ENUM	NOT NULL	Discovery Agent	Values: active dormant disabled orphaned pending_review. Drives Exposure score component.
<code>nhi_source_systems</code>	VARCHAR(500)	NOT NULL	Discovery Agent	Comma-separated source systems. Example: AD,EntralD,Okta. Used for deduplication merge confidence.
<code>nhi_last_used_datetime</code>	TIMESTAMP	NULLABLE	IdP / Agent	UTC timestamp of last observed authentication. NULL if no auth event in observation window.
<code>nhi_identity_trurisk_score</code>	DECIMAL(6,2)	NULLABLE	ETM Engine	Per-NHI TruRisk score on 1–2000 ETM scale. NULL until first scoring cycle. Re-computed on any state change.
<code>nhi_exposure_score</code>	DECIMAL(4,2)	NULLABLE	ETM Engine	Component (0–10): missing MFA, stale credentials, excessive privilege, dormant-but-enabled, shared credential.

<code>nhi_exploitability_score</code>	DECIMAL(4,2)	NULLABLE	Threat Intel	Component (0-10): active targeting of this NHI class, exploit techniques (Kerberoasting, ASREP-Roasting), active campaigns last 30 days.
<code>nhi_blast_radius_score</code>	DECIMAL(4,2)	NULLABLE	ETM Engine	Component (0-10): $\text{asset_criticality_tier} \times \text{privileged_group_membership} \times \text{hop_count_to_tier0}$ (inverse).
<code>nhi_attack_path_count</code>	INTEGER	DEFAULT 0	Graph Engine	Active attack paths through this NHI to Tier-0 assets. Decrement on TruConfirm re-validation after fix.
<code>nhi_is_chokepoint</code>	BOOLEAN	DEFAULT FALSE	Graph Engine	TRUE when $\text{nhi_attack_path_count} \geq 3$ distinct paths to critical assets. Surfaced at top of ROC analyst workload.
<code>nhi_owner_attributed</code>	VARCHAR(255)	NULLABLE	Attribution Model	Inferred owner team/user. NULL when no signal meets confidence threshold (default 40%). Shown as Unattributed in UI.
<code>nhi_owner_confidence_pct</code>	DECIMAL(4,1)	NULLABLE	Attribution Model	Confidence % (0.0-100.0) for attribution. Weighted sum of 4 signals. Updates after each human confirmation event.
<code>nhi_owner_confirmed_by</code>	VARCHAR(255)	NULLABLE	Human Confirm Event	User principal who last confirmed or reassigned ownership. NULL if never human-confirmed. Stored for audit trail.
<code>nhi_attribution_signals</code>	VARCHAR(500)	NULLABLE	Attribution Model	JSON map of 4 signal scores. Keys: <code>creating_account</code> , <code>ticket_history</code> , <code>naming_convention</code> , <code>recent_interactive_users</code> .
<code>nhi_itsm_ticket_id</code>	VARCHAR(100)	NULLABLE	ITSM Integration	External ITSM ticket ID (ServiceNow / Jira). NULL if no remediation ticket created for this NHI.
<code>nhi_trueconfirm_status</code>	ENUM	DEFAULT 'not_triggered'	TruConfirm Engine	Values: <code>not_triggered</code> <code>pending</code> <code>passed</code> <code>failed</code> . <code>failed</code> auto-reopens the ITSM ticket with re-validation failure reason.
<code>nhi_remediation_action</code>	VARCHAR(200)	NULLABLE	ITSM Closure Event	Action applied on ticket close. Examples: <code>credential_rotated</code> , <code>account_disabled</code> , <code>privilege_reduced</code> , <code>mfa_enforced</code> .
<code>nhi_privileged_group_member</code>	BOOLEAN	DEFAULT FALSE	Discovery Agent	TRUE if NHI holds membership in Domain Admins, Enterprise Admins, or Global Administrator. Auto-elevates Blast Radius score.

nhi_mfa_status	ENUM	NULLABLE	IdP Source	Values: enrolled not_enrolled not_applicable unknown. not_applicable for service accounts where MFA is architecturally unsupported.
nhi_credential_age_days	INTEGER	NULLABLE	IdP Source	Days since credential last rotated. Computed from IdP metadata. NULL when rotation date is unavailable from source.
nhi_compliance_tags	VARCHAR(300)	NULLABLE	Compliance Engine	Applicable frameworks: NIS2 NERC_CIP IEC_62443 SOC2 PCI_DSS. Drives compliance export and scoring adjustments.

Data Instrumentation

Below are the events and variables that will track key functional metrics:

Key Metric	Event Name	Variables Tracked
↓ Aggregate NHI Identity TruRisk Score (North Star)	nhi_score_calculated	nhi_id, nhi_identity_trurisk_score, nhi_exposure_score, nhi_exploitability_score, nhi_blast_radius_score, score_version, scan_cycle_id, calculation_duration_ms
↑ NHI Discovery Coverage %	nhi_scan_completed	scan_cycle_id, source_system, nhi_count_discovered, nhi_count_deduplicated, coverage_pct_estimated, scan_duration_ms, connector_version
↑ % NHIs with Attributed Owner	nhi_owner_attributed_event	nhi_id, owner_attributed, owner_confidence_pct, attribution_signals_json, is_new_attribution, previous_owner
Human Confirmation Rate & Model Accuracy	nhi_owner_confirmed / nhi_owner_reassigned	nhi_id, previous_owner, new_owner, confirmed_by_user_id, confirmation_datetime, confidence_delta
↓ # Open Toxic Attack Paths	attack_path_graph_updated	nhi_id, path_id, path_hop_count, target_asset_id, target_asset_tier, is_chokepoint, path_risk_score, graph_computation_ms
↓ MTTR on Flagged NHI (created)	itsm_ticket_created	nhi_id, ticket_id, ticket_system, owner_assigned, blast_radius_note_included, remediation_type, ticket_created_datetime
↓ MTTR on Flagged NHI (closed)	itsm_ticket_closed	nhi_id, ticket_id, ticket_closed_datetime, time_to_close_hours, remediation_action, resolution_notes_length
TruConfirm Re-validation Pass Rate	trueconfirm_revalidation_run	nhi_id, ticket_id, revalidation_status, attack_path_still_exists, score_delta, revalidation_duration_ms, revalidation_datetime
% Recommendations → ITSM Tickets	remediation_recommended	nhi_id, recommendation_type, recommendation_datetime, recommendation_rank_at_time, analyst_user_id
Ticket Abandonment Rate (Failure Metric)	itsm_ticket_abandoned	nhi_id, ticket_id, assigned_owner_persona, time_in_open_state_hours, abandonment_reason, escalation_triggered

System Design

Architecture Overview: ETM Identity operates as an intelligence overlay — consuming signals from identity sources and producing a unified risk picture. It does not write to AD/Entra/Okta; it reads and enriches.

Components: (1) Discovery Connectors → (2) Deduplication & Normalisation Engine → (3) TruRisk Scoring Pipeline → (4) Ownership Attribution Model → (5) Attack-Path Graph Engine → (6) ROC Worklist UI → (7) ITSM Integration Layer → (8) TruConfirm Re-validation → (9) Audit Trail DB

Scenario-Based Tests (Edge Cases)

ID	Objective & Preconditions	Test Input	Acceptable Outcome	Failure Outcome
1	Objective: Deduplication — same NHI in multiple sources Precondition: svc-deploy exists in both AD and Entra ID	Discovery scan runs with both AD and Entra connectors connected	One merged NHI record with Sources: AD, EntraID. No duplicate entries.	Two separate records — triggers a deduplication pipeline alert to engineering
2	Objective: Ownership attribution — no signal matches Precondition: NHI has no ServiceNow history, no naming convention match, no creating account data	Orphaned API key, created 3 years ago by a deleted user	NHI shown as 'Unattributed' with confidence 0%. Analyst prompted to manually assign owner.	System assigns a random or stale owner — triggers false attribution alert
3	Objective: Attack-path graph — cyclic dependency Precondition: NHI-A has access to NHI-B, which has access back to NHI-A	Graph engine processes circular entitlement chain	Cycle is detected and broken at the lowest-risk node. Graph renders without infinite loop.	Graph engine hangs / crashes — engineering incident
4	Objective: TruConfirm re-validation after rotation Precondition: ITSM ticket closed, claimed rotation of svc-deploy	Ticket closure event triggers re-validation scan	If svc-deploy still has same entitlements → ticket re-opened with 'Re-validation Failed'. If rotated → score updates and path count drops.	Re-validation runs but result is not written to ticket — analyst has no feedback
5	Objective: ITSM API down during remediation Precondition: Analyst clicks 'Remediate' on a high-risk NHI	ITSM ServiceNow API returns 503	Graceful degradation: UI shows 'ITSM unavailable — copy remediation details'. NHI stays in 'Pending Remediation' state. Alert sent to platform team.	UI crashes or shows blank state — analyst loses remediation context
6	Objective: Connector returns partial data Precondition: Entra	Entra connector returns 60% of expected NHI count (vs baseline)	Coverage % drops and is surfaced as a warning: 'Entra ID scan	System shows 100% coverage — analyst believes inventory is

	ID connector times out mid-scan		incomplete — 40% of expected NHIs not returned. Results may be partial.'	complete when it isn't
--	---------------------------------	--	--	------------------------

Launch Readiness

Below is the overall checklist for v0 launch readiness (Discovery & Inventory — target Q3 2026):

S/N	Milestone	Status	Checklists	Timeline
1	Design Sign-Off (v0)	Completed	- Med-fidelity wireframes for NHI inventory list view - High-fidelity mockups for Identity Record Card - Design review with ROC Analyst (design partner)	Q2 W1-W2
2	PRD Sign-Off for v0 MVP	Completed	- Problem validation complete - User stories updated with AC - Dev & analytics queries resolved	Q2 W2-W3
3	Connector Development (AD, Entra, Okta)	In Progress	- AD connector — sign-off on technical spec - Entra ID connector — sign-off on API permissions - Okta connector — development sprint 1 - Integration tests with deduplication engine	Q2 W3 – Q3 W2
4	TruRisk Pipeline Scoring	In Progress	- Scoring formula validated with Threat Research team - Re-scoring trigger on state change — unit tests - Integration with existing TruRisk normalisation layer	Q2 W4 – Q3 W2
5	QA Testing	Not Started	- Scenario-based tests (edge cases 1–6 above) - Connector failure/partial data tests - Performance tests — scan latency under load - Coverage % accuracy test	Q3 W1-W3
6	Dogfooding (Internal UAT)	Not Started	- Alpha test sign-off (internal ROC team) - Beta test with 2 design-partner customers - A/B test — worklist view vs. flat list — sign-off	Q3 W2-W4
7	KPI Dashboard	Not Started	- New metrics added to ROC dashboard - Data pipeline integrity test - Audit trail export verified for Compliance persona	Q3 W3 – Q3 W4

8	Launch Communication	Not Started	• Customer comms — in-app banner + email for ETM Identity customers • Sales enablement deck updated • Qualys.com product page updated (public materials only)	Q3 W4
---	----------------------	-------------	---	-------

Future Iterations

Goal for v2–v3: Close the remediation loop completely (v2), then automate NHI rotation with guardrails (v3). Increase review engagement and social proof for analyst actions.

User Story	High-Level Idea	Version	Priority
"As a ROC Analyst, I want TruConfirm to automatically re-validate that a remediated path is actually gone, so that I can close tickets with confidence."	On ticket closure, ETM Identity re-scans the NHI's entitlements and attack-path graph. If path persists → ticket auto-reopened with 'Re-validation Failed' status. CISO sees a 'Paths Closed (Verified)' count, not just 'Tickets Closed'.	v2	P1
"As a CISO, I want to see a single QoQ Identity TruRisk trend for my organisation, so that I can report to the board that identity exposure is actually decreasing."	Aggregate NHI Identity TruRisk score tracked QoQ. Sliceable by business unit, asset classification, and NHI type. Exportable as a board-ready PDF with BEFORE/AFTER context for each remediation cycle.	v2	P1
"As an App Owner, I want a staged rotation option so that I can rotate a service account in dev before I touch production."	ETM Identity detects environment tiers (dev/stage/prod) from asset tags. Staged rotation wizard: 1) rotate in dev, 2) monitor for 48h, 3) proceed to stage, 4) proceed to prod. Blast-radius re-calculated after each stage.	v2	P1
"As an Identity Security Analyst, I want review filtering by word search and AI keyword summary, so that I can process the worklist faster."	Analyst can filter the NHI worklist by text search across all metadata fields. AI-generated one-line risk summary for each NHI (e.g., 'Stale service account with domain-admin path to 3 Tier-0 assets — last used 180 days ago').	v2	P2
"As a ROC Analyst, I should be able to orchestrate automated credential rotation for NHIs with low blast radius, so that I don't spend analyst time on low-risk routine rotations."	ETM Identity identifies NHIs with a blast-radius score below a configurable threshold (e.g., no Tier-0 dependencies). For these, automated rotation via CyberArk/Delinea API is triggered on a defined schedule. Human approval required for medium-blast-radius NHIs.	v3	P1
"As an analyst, I want to use voice input to log remediation notes, so that I can work hands-free during incident response."	Voice-to-text (online ASR, Google Cloud Speech / AWS Transcribe) for remediation note capture on ITSM ticket. Notes undergo NLU content moderation before submission. Graceful fallback to text if ASR unavailable. (Analogous to Zomato's voice review feature but in B2B remediation context.)	v3	P2
"As an analyst, I should be notified when a previously-remediated NHI resurfaces as high-risk, so that I feel the real impact of my work being undone."	Live alerts: when a TruConfirm-verified 'closed' NHI re-enters a high-risk state (e.g., privilege re-escalation), the original analyst receives a notification similar to LinkedIn interaction alerts. Creates a sense of ongoing ownership.	v3	P2
"As an analyst using a non-English	NHI risk summaries and remediation notes	v3	P3

interface, I want the NHI risk summary in my local language, so that I have a native experience."	are available in 5 languages: English, German, Japanese, Spanish, French. Translation via existing Qualys localisation pipeline.		
---	--	--	--

Portfolio Disclaimer: This document is an unsolicited PRD written by Kushal Zambare based solely on public Qualys ETM Identity materials (October 2025 ROCon Houston, Qualys product documentation). It is not affiliated with or endorsed by Qualys, Inc. All sizing numbers are illustrative assumptions, not internal Qualys data.